

MODULE 17 · DOMAIN 4 - DATA SECURITY AND GOVERNANCE

Authentication and network access

IAM roles, federation, secrets, VPC endpoints, PrivateLink and the boundary around your data.

DOMAIN 4 of 4 EXAM WEIGHT 18% MODULE 17 of 27

Authentication asks **who are you.**
Authorisation asks **what may you do.** This
module is the first.

The identity types

IDENTITY	USED FOR
IAM role	The default for everything. Temporary credentials, no secrets to store
IAM user	A long-lived identity with access keys. Avoid for workloads
Federated identity	Corporate directory users, through IAM Identity Center or SAML
Service-linked role	A role a service creates and manages for its own operations
Root user	Account creation and a handful of tasks. Not for daily work

ON THE EXAM

If an option involves creating an IAM user for an application or a pipeline, it is almost certainly wrong.

Protecting the account itself

- ◆ **MFA is now enforced for root users** across AWS accounts.
- ◆ **Root has no permission boundary.** No policy can restrict it.
- ◆ **Lock it away.** Use it for account setup and the few tasks that require it.
- ◆ **CloudTrail on root activity** should alarm, because it should be rare.
- ◆ **Organizations and SCPs** restrict member accounts, not the management account root.

ON THE EXAM

Root usage is a signal in itself. An alarm on any root API call is a standard control.

Credentials in code, in a config file, or in a job parameter are **always** the wrong answer.

How each service gets an identity

- ◆ **AWS Lambda** assumes its execution role for every invocation.
- ◆ **AWS Glue jobs** assume the role named in the job definition.
- ◆ **Amazon Redshift** uses attached roles for COPY, UNLOAD and Spectrum.
- ◆ **Amazon EC2** uses an instance profile, which delivers role credentials.
- ◆ **Amazon EKS** uses roles for service accounts, so each pod has its own identity.
- ◆ **A partner API credential** has no AWS role. That is Secrets Manager.

ON THE EXAM

The last row is the boundary. Roles cover AWS access. Anything outside AWS needs a stored secret.

Least privilege, in practice

- ◆ **Grant the actions actually used**, not a wildcard on the service.
- ◆ **A star on a service** grants every action it will ever have, including future ones.
- ◆ **Scope resources too**, naming the buckets and tables rather than all of them.
- ◆ **Conditions narrow further**, by source VPC, tag, or encryption requirement.
- ◆ **Separate roles per job** so one pipeline's compromise is not every pipeline's.

ON THE EXAM

A role granting `s3:*` on every bucket is the most common finding in any AWS security review.

Identity-based or resource-based policy?

IDENTITY-BASED

Attached to the principal

- On a role, user or group
- Says what this identity may do
- The usual place permissions live
- Cannot grant access to another account alone

RESOURCE-BASED

Attached to the resource

- On a bucket, queue, topic or KMS key
- Says who may use this resource
- Names the principal explicitly
- Enables cross-account access directly

THE TIEBREAKER

Cross-account access usually needs both. The resource allows the principal, and the principal's policy allows the action.

Assuming a role

- ◆ A **trust policy** says who is allowed to assume the role.
- ◆ A **permissions policy** says what the role can do once assumed.
- ◆ AWS STS issues **temporary credentials**, valid for a session you bound.
- ◆ An **external ID** protects against the confused deputy problem with third parties.
- ◆ A **missing trust policy entry** fails at assume time, not at action time.

ON THE EXAM

Two policies, two different questions. Who may become this role, and what may this role do.

An AWS Glue job reads from Amazon S3, writes to Amazon Redshift, and calls a partner API for exchange rates. The job currently holds an AWS access key and secret key as job parameters, plus the partner's API key in the same place.

A security review has required that no long-lived AWS credentials exist anywhere, and that the partner credential can be rotated without editing the job.

What should the data engineer implement?

- A Move all three credentials into AWS Secrets Manager and read them at job start
- B Attach an IAM role to the Glue job for AWS access, and store the partner API key in AWS Secrets Manager with rotation enabled
- C Move all three credentials into Systems Manager Parameter Store as SecureString parameters
- D Rotate the AWS access keys every thirty days using a scheduled Lambda function

◆ PAUSE AND DECIDE

What should the data engineer implement?

- A

All three into Secrets Manager

Stores the AWS keys more safely rather than eliminating them. Long-lived AWS credentials still exist, which the review forbade.
- C

All three in Parameter Store

Same objection as A, and Parameter Store has no rotation, which the second requirement asked for.
- B

Role for AWS, Secrets Manager for the partner key

The role removes the AWS credentials entirely; Secrets Manager holds and rotates the one credential a role cannot represent.
- D

Rotate the access keys on a schedule

Keeps long-lived credentials and adds machinery to manage them. It reduces exposure without removing it.

THE SIGNAL

Two credentials of different kinds. The AWS one should not exist; the partner one must be stored somewhere.

Authenticating to a database

- ◆ **IAM database authentication** for Amazon RDS and Aurora, issuing a token instead of a password.
- ◆ **Tokens expire in fifteen minutes**, so nothing long-lived is stored.
- ◆ **Redshift GetClusterCredentials** does the equivalent, mapping an IAM identity to a database user.
- ◆ **Amazon MSK IAM access control** authenticates Kafka clients with IAM.
- ◆ **Where the engine cannot do this**, a stored password in Secrets Manager is correct.

ON THE EXAM

Several data services can authenticate with IAM directly, which removes the password entirely rather than storing it better.

People, rather than services

- ◆ **IAM Identity Center** is the front door for human access across accounts.
- ◆ **Connects to a corporate directory**, so joiners and leavers are handled once.
- ◆ **Permission sets** map a group to a role in each account they can reach.
- ◆ **An IAM user per engineer per account** is how credential sprawl happens.
- ◆ **MFA is now enforced for root users**, and root should not be used regardless.

ON THE EXAM

Federation means access ends when employment ends. Individual IAM users outlive the people who owned them.

How a request is actually evaluated

- ◆ **Everything is denied by default.** Access requires an explicit allow.
- ◆ **An explicit deny always wins,** from any policy in the evaluation.
- ◆ **Service control policies** set a ceiling for an account, and grant nothing.
- ◆ **Resource control policies** do the same for resource-based policies.
- ◆ **Permissions boundaries** cap what a role can be granted, delegating safely.

ON THE EXAM

An SCP that allows something grants nothing. It only removes the ability to deny it further up.

A data lake bucket lives in a central account. An analytics team in a second account needs read access from a Glue job. The bucket policy has been updated to allow the second account's Glue role, and the job still fails with an access denied error on GetObject.

The Glue role in the second account has a policy granting glue:* and logs:* only. There are no service control policies restricting Amazon S3.

What is the most likely cause?

- ☐ A The bucket policy must name the second account's root user rather than the role
- ☐ B The Glue role's own policy does not allow s3:GetObject. Cross-account access needs both sides
- ☐ C Cross-account access to Amazon S3 requires an S3 Access Point
- ☐ D The bucket must be made public for another account to read it

◆ PAUSE AND DECIDE

What is the most likely cause?

- A

 Name the root user instead
Naming an account root in a bucket policy delegates to that account, and the role still needs its own permission. It does not fix this.
- B

 The role's own policy lacks s3:GetObject
The role is granted glue and logs only. Cross-account access requires the resource to allow the principal and the principal to allow the action.
- C

 An Access Point is required
Access Points simplify managing access at scale. They are not a prerequisite for cross-account reads.
- D

 Make the bucket public
Public access is not how cross-account works, and it would be a serious security failure.

THE SIGNAL

The role's policy is quoted in the question. Glue and logs, with no S3 at all. That is the planted detail.

Some credentials cannot be a role. Those have to live somewhere, and **where** is examinable.

Secrets Manager or Parameter Store?

AWS SECRETS MANAGER

Secrets that rotate

- Automatic rotation on a schedule
- Rotates the credential and the stored value together
- Cross-account and cross-Region replication
- Charged per secret per month

SYSTEMS MANAGER PARAMETER STORE

Configuration

- Standard parameters are free
- SecureString encrypts with KMS
- No rotation capability
- Bucket names, thresholds, feature flags

THE TIEBREAKER

Rotation is the deciding capability. A question mentioning rotating a credential automatically has one answer.

How rotation actually works

- ◆ **A rotation function** creates a new credential and updates the stored secret.
- ◆ **Built in** for RDS, Aurora, Redshift, DocumentDB and a few others.
- ◆ **Custom rotation** through a Lambda function for anything else.
- ◆ **Applications read the secret each time**, so they never hold a stale value.
- ◆ **An application caching the secret at start-up** breaks the moment it rotates.

ON THE EXAM

Rotation only works if consumers fetch the current value. Caching a secret forever defeats the point of rotating it.

Authentication decides who you are. The **network** decides whether you can get there at all.

Security groups or network ACLs?

SECURITY GROUP

Around the resource

- Stateful. A reply to allowed traffic is allowed
- Allow rules only. No explicit deny
- Attached to an ENI, so it follows the resource
- Can reference another security group

NETWORK ACL

Around the subnet

- Stateless. Return traffic needs its own rule
- Allow and deny rules, evaluated in order
- Applies to everything in the subnet
- Blunter, and used for broad blocks

THE TIEBREAKER

Stateful against stateless is the distinction. A security group that allows an inbound request allows the reply automatically.

Where a data service actually runs

- ◆ **Amazon MSK, Amazon RDS and EMR** live in your subnets, with private addresses.
- ◆ **Glue and Lambda** run outside your VPC until you attach a connection or configure one.
- ◆ **Attaching a VPC to Lambda** adds cold start time and removes default internet access.
- ◆ **Kinesis, Athena and DynamoDB** are regional endpoints, reached over the network.
- ◆ **Interface endpoints** are what make those regional services reachable privately.

ON THE EXAM

Knowing which services sit inside your VPC and which are reached across it decides most connectivity questions.

Getting to a service privately

MECHANISM	CHARACTER
Gateway endpoint	S3 and DynamoDB only. A route table entry. No hourly charge
Interface endpoint	Almost everything else. An ENI with a private IP, via PrivateLink
NAT gateway	Outbound to the internet from a private subnet, with a fixed address
Site-to-Site VPN	On-premises to AWS over the internet, encrypted
AWS Direct Connect	A dedicated circuit. Consistent bandwidth and latency

ON THE EXAM

A gateway endpoint is a route, not a device. If it is not in the subnet's route table, it does nothing at all.

AWS PrivateLink

- ◆ **Traffic stays on the AWS network**, never traversing the public internet.
- ◆ **Interface endpoints are PrivateLink**, for AWS services and partner services.
- ◆ **Endpoint policies** restrict which resources can be reached through the endpoint.
- ◆ **Expose your own service** to other accounts without peering VPCs.
- ◆ **Not free.** Hourly per endpoint per Availability Zone, plus data processed.

ON THE EXAM

An endpoint policy is a second place permissions live. A bucket can be reachable and still refused at the endpoint.

Keeping traffic inside a boundary

- ◆ **A data perimeter** combines identity, resource and network controls.
- ◆ **Only trusted identities** reach your resources, enforced by RCPs.
- ◆ **Only trusted resources** are reachable from your network, enforced by endpoint policies.
- ◆ **Only expected networks** can reach your data, enforced by conditions on source VPC.
- ◆ **Block Public Access** at account level, so no individual bucket can be exposed.

ON THE EXAM

Three controls, three directions. Who can get in, what can be reached, and from where.

S3 Access Points

- ◆ A named endpoint attached to a bucket, each with its own policy.
- ◆ One consumer, one access point, instead of one growing bucket policy.
- ◆ Can be restricted to a VPC, so the data is unreachable from the internet.
- ◆ Multi-Region Access Points give one endpoint across Regions.
- ◆ Object Lambda transformed data on retrieval, and is now closed to new customers.

ON THE EXAM

Module eight promised this. Access Points exist because a shared bucket policy becomes unmaintainable.

A financial services company runs Glue jobs in private subnets. A compliance requirement states that no data may traverse the public internet, and that jobs must be able to reach only two named S3 buckets, not any bucket in AWS.

The subnets currently route outbound traffic through a NAT gateway, and the jobs reach Amazon S3 over the public endpoint.

What should the data engineer implement?

- ☐ A Add an S3 gateway endpoint with an endpoint policy naming the two buckets, and remove the NAT route for S3
- ☐ B Keep the NAT gateway and add a bucket policy on each of the two buckets
- ☐ C Add an interface endpoint for Amazon S3 and rely on the Glue role's IAM policy
- ☐ D Move the Glue jobs to public subnets so the routing is simpler

◆ PAUSE AND DECIDE

What should the data engineer implement?

- A** Gateway endpoint with an endpoint policy
Traffic leaves the internet path entirely, and the endpoint policy restricts which buckets are reachable through it. Both requirements.
- B** NAT plus bucket policies
Bucket policies control your buckets. They do nothing about traffic to somebody else's bucket, and traffic still uses the internet path.
- C** Interface endpoint plus the IAM policy
Keeps traffic private, and an IAM policy governs the identity rather than the network path. Closer, and it misses the endpoint restriction.
- D** Public subnets
Solves a routing inconvenience by putting the jobs on the internet, which is the opposite of the requirement.

THE SIGNAL

Two requirements: private path, and a restricted set of destinations. Only the endpoint policy delivers the second.

Where the responsibility sits

- ◆ **AWS secures the cloud.** Facilities, hardware, and the managed service itself.
- ◆ **You secure what you put in it.** Data, identities, policies, network configuration.
- ◆ **More managed means less surface,** but never zero responsibility.
- ◆ **On EC2 or self-managed Kafka,** patching and hardening are yours.
- ◆ **Encryption and access control are always yours,** whatever the service.

ON THE EXAM

The exam guide names understanding managed versus unmanaged services as a skill. The line moves; it never disappears.

Finding permissions you did not intend

- ◆ **IAM Access Analyzer** reports resources reachable from outside the account.
- ◆ **Unused access findings** identify roles and permissions nobody has exercised.
- ◆ **Policy validation** checks a policy against best practice before deployment.
- ◆ **Policy generation** proposes a least-privilege policy from CloudTrail history.
- ◆ **Permissions only ever accumulate** unless something actively removes them.

ON THE EXAM

Generating a policy from observed activity is how least privilege becomes practical rather than aspirational.

A company has twelve AWS accounts and around forty engineers. Each engineer has an IAM user in every account they work in, with access keys for CLI use. Three people have left in the past year and the security team is not confident all their credentials were removed.

The company wants access tied to employment, and wants to stop issuing long-lived keys.

What should the company implement?

- A A scheduled Lambda function that deletes IAM users not seen in ninety days
- B AWS IAM Identity Center federated to the corporate directory, with permission sets granting roles per account
- C Enforce a ninety day access key rotation policy across all accounts
- D Consolidate the twelve accounts into one so there is a single set of users

◆ PAUSE AND DECIDE

What should the company implement?

- A

 Delete unused users automatically
Cleans up after the problem on a ninety day delay, and a departed engineer's key is valid throughout that window.
- B

 Identity Center federated to the directory
Identity lives in one place tied to employment, and access is temporary role credentials rather than keys.
- C

 Ninety day key rotation
Shortens the life of a leaked key and keeps long-lived keys in existence, which the company said it wanted to stop.
- D

 Consolidate to one account
Removes the account boundary that separates environments and teams, to fix an identity problem.

THE SIGNAL

"Access tied to employment" is the phrase. Only federation makes leaving the company remove AWS access.

Symptoms and their causes

SYMPTOM	LIKELY CAUSE
Cross-account access denied after a bucket policy update	The other side's identity policy does not allow the action
A VPC endpoint exists and does nothing	No route in the subnet's route table
Glue workers cannot talk to each other	Security group missing a self-referencing rule
Access denied that no IAM policy explains	An SCP, an RCP, or an endpoint policy
An application breaks when a secret rotates	The secret was cached at start-up
Intermittent failures calling a partner API	Source IP changes. Route through a NAT gateway

ON THE EXAM

The fourth row is the one people chase for hours. Three other files can deny a request that IAM permits.

Reading an authentication question quickly

- ◆ **Are credentials being stored?** If they are AWS credentials, that is wrong.
- ◆ **Is it AWS or outside AWS?** Roles for the first, Secrets Manager for the second.
- ◆ **Cross-account?** Both sides must allow it. Check which half the question gave you.
- ◆ **Identity or network?** A permission problem and a reachability problem look alike.
- ◆ **Does rotation appear?** That single word decides Secrets Manager over Parameter Store.

ON THE EXAM

Next: authorisation. IAM policies, Lake Formation, and controlling access to columns and rows.